

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

BUSINESS CONTINUITY PLAN

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PLN013_00	00	30/04/2026	6
Redatto da	Approvato da	Classificazione	Stato
IT Manager + RSGI + AD	AD – Francesco Epifani	Riservato Alta Direzione + Auditor	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
30/04/2026	30/04/2026	30/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito

Il Business Continuity Plan (BCP) di Toscana Diagnostica S.r.l. definisce il quadro organizzativo, le responsabilità, le procedure e le risorse necessarie a garantire la continuità dei processi critici aziendali a fronte di eventi disruptive — naturali, tecnologici, dolosi o di compliance — che ne minaccino la regolare erogazione.

Il Piano è coerente con: ISO/IEC 22301:2019 (BCMS) — adottata come framework metodologico in roadmap di certificazione formale 2027; ISO/IEC 27001:2022 §A.5.29-A.5.30; D.Lgs. 138/2024 (NIS2) art. 24 c. 2 area MTOM 3 (continuità operativa); requisiti di accreditamento sanitario applicabili.

Ambito: tutti i processi sanitari, amministrativi, ICT e di supporto di TD, includendo le sedi operative, i sistemi informativi, i fornitori critici. Il presente BCP è completato dal Disaster Recovery Plan TD-SGI-PLN014 — focalizzato sull'aspetto ICT — e dal Piano di Emergenza ex D.M. 02/09/2021 (in arrivo) — focalizzato sull'aspetto fisico/sicurezza dei lavoratori.

2. Riferimenti

Riferimento	Ambito
ISO/IEC 22301:2019 - Business Continuity Management Systems	Framework metodologico
ISO/IEC 27001:2022 §A.5.29-A.5.30	Continuità ICT nell'ISMS
D.Lgs. 138/2024 (NIS2) art. 24 c. 2	MTOM area 3 - continuità operativa
TD-SGI-POL001	Politica integrata - dimensione resilienza
TD-SGI-PRO109	Information Security Policy operativa
TD-SGI-PLN014	Disaster Recovery Plan (componente ICT del BCP)
TD-SGI-PLN009	Piano MTOM NIS2
TD-SGI-MOD221	Verbale Test BCP/DRP
Piano di Emergenza ex D.M. 02/09/2021	Componente fisica/safety - in arrivo

3. Governance del BCP

La governance del BCP è strutturata come segue:

Ruolo	Responsabilità BCP
Alta Direzione (AD)	Approvazione del BCP; allocazione risorse; attivazione del Crisis Management Team in caso di evento di livello critico
Crisis Management Team (CMT)	Comando e controllo durante la crisi: AD (chair) + RSGI + IT Manager + Direttore Sanitario + RSPP + DPO + P&C + Comunicazione
RSGI	Coordinamento operativo del BCP; manutenzione del Piano; calendario test
IT Manager	Esecuzione DRP (PLN014); ripristino sistemi informativi; comunicazione tecnica al CMT
Direttore Sanitario	Continuità clinica; protocolli alternativi su carta; comunicazione ai pazienti

Direttore Laboratorio	Continuità analitica; protocolli alternativi; coordinamento con laboratori partner per esami non differibili
RSPP	Continuità safety operativa; coordinamento con il Piano di Emergenza
DPO	Coordinamento sui data breach derivanti da incidenti che attivano BCP
P&C Manager	Gestione personale durante la crisi (turnistica, comunicazione, smart working d'emergenza)
Comunicazione	Comunicazione esterna verso pazienti, media, autorità

4. Business Impact Analysis (BIA)

L'analisi di impatto identifica i processi aziendali critici e le tolleranze massime di interruzione. La BIA è aggiornata almeno annualmente.

Processo	Criticità	MTPD (max tollerabile)	RTO (recovery time)	RPO (recovery point)	Risorse minime per mode survival
Refertazione esami già eseguiti	Critica	8 ore	≤ 4 ore	≤ 4 ore	LIS attivo o procedura cartacea
Esecuzione esami urgenti (pronto soccorso/ricoveri)	Critica	4 ore	≤ 2 ore	≤ 1 ora	Strumentazione attiva + personale + connettività ad almeno 1 ospedale partner
Diagnostica per immagini urgente	Critica	8 ore	≤ 4 ore	≤ 2 ore	RIS/PACS + radiologo reperibile
Accettazione paziente	Alta	12 ore	≤ 6 ore	≤ 6 ore	Modulo cartaceo + identificazione manuale
Esecuzione esami programmati (non urgenti)	Media	48 ore	≤ 24 ore	≤ 12 ore	Riprogrammazione possibile
Fatturazione SSN	Media	5 giorni lavorativi	≤ 72 ore	≤ 24 ore	Sistema ERP + fatturazione elettronica
HR / Payroll	Bassa	10 giorni	≤ 5 giorni	≤ 24 ore	Backup mensile + servizio esterno
Comunicazione esterna	Media	12 ore	≤ 6 ore	≤ 1 ora	Sito web + canali social + PEC

5. Scenari di crisi prevedibili e strategie di risposta

Scenario	Frequenza attesa	Strategia di risposta	Documenti operativi
Indisponibilità prolungata LIS/RIS/PACS	1-2/anno minore; 1/3-5 anni maggiore	Attivazione DRP (PLN014); modalità cartacea; coordinamento con vendor; comunicazione pazienti	PLN014 §6

Cyber-incident significativo (ransomware, esfiltrazione)	Crescente - rischio settore sanitario alto	Attivazione catena PRO070 (NIS2) + DRP + comunicazione AC	PRO070 + PLN014 + MOD181
Indisponibilità sede principale (incendio, alluvione)	Bassa	Smart working personale amministrativo; trasferimento attività urgenti a sede partner; ripristino vital records dal datacenter remoto	Piano Emergenza + PLN013
Pandemia / emergenza sanitaria	Verificata 2020-2022	Smart working esteso; protocolli sanitari rinforzati; PPE; turnistica	Procedure 2020-2022 da capitalizzare
Attacco fisico / minacce a operatori	Bassa	Procedura PRO028 + lockdown + Polizia	PRO028
Indisponibilità prolungata fornitore critico ICT	Bassa	Attivazione clausole NIS2 contrattuali; backup operativo; emergency procurement	PRO070 §8 + MOD182
Indisponibilità personale critico (epidemia, sciopero)	Bassa	Backup di ruolo (matrice di sostituzione); attivazione personale somministrato; modulazione dei servizi non urgenti	Mansionario REG021 (in arrivo)

6. Procedura di attivazione del BCP

Fase	Trigger	Azione richiesta	Responsabile	T target
F1 Detection	Allerta da fonte (SOC, IT, personale, fornitore, autorità)	Apertura ticket CMT; valutazione preliminare; chiamata reperibile AD	Chi rileva + IT Manager	T0+15'
F2 Activation	Conferma evento di livello critico	Convocazione formale CMT; apertura war-room virtuale o fisica	AD + RSGI	T0+30'
F3 Stabilization	CMT in sessione	Decisioni operative immediate (ridondanza, switch fornitori, comunicazione interna)	CMT	T0+1h
F4 Continuity Operations	Modalità operativa alternativa	Esecuzione delle procedure di continuità per ciascun processo critico	Owner di processo	T0+2h - T0+RTO
F5 Recovery	Sistemi e processi tornano alla modalità nominale	Esecuzione DRP per ICT; rientro graduale in modalità nominale; verifica integrità dati	IT Manager + Direttore Lab	T0+RTO ÷ T0+24h
F6 Post-incident review	Crisi chiusa	Verbale crisi; RCA; CAPA; lessons learned; aggiornamento del Piano	RSGI	T0+30gg

7. Comunicazione di crisi

La comunicazione interna (personale TD) è gestita dal CMT con cadenza appropriata: messaggio iniziale entro T0+1h, aggiornamenti a T0+4h e ad ogni cambiamento materiale.

La comunicazione esterna (pazienti, fornitori, media, autorità) è gestita dalla funzione Comunicazione coordinata dall'AD, con eventuale supporto di consulente PR di crisi. Per pazienti con esami in corso: contatto diretto telefono + email + SMS, con istruzioni operative (riprenotazione, esiti via canale alternativo).

Comunicazione alle autorità: ACN/CSIRT (se cyber-incident NIS2 - PRO070); Garante Privacy (se data breach - 72h); Ministero Salute / Regione Toscana (se sospensione di servizi SSN); Polizia Postale (se cyber-reato).

8. Test e manutenzione del BCP

Tipo test	Cadenza	Scopo	Output
Walk-through	Semestrale	Revisione tavolino del Piano con CMT - validazione dei contatti, delle procedure, delle dipendenze	MOD221 verbale + lista azioni
Tabletop exercise (BCP+NIS2)	Annuale	Simulazione scenario realistico con coinvolgimento CMT esteso - allineata a tabletop NIS2 (MOD183)	MOD183 + MOD221 (verbale unico)
Test funzionale DRP	Annuale	Test di ripristino effettivo da backup su sistema test - validazione RTO/RPO	MOD221 §3 - test ripristino
Test full-scale	Triennale	Simulazione completa con switchover su sito secondario - validazione fattibilità reale	MOD221 §4 - test full-scale
Manutenzione del Piano	Annuale + on-event	Revisione del Piano in base a lessons learned, cambiamenti del business, evoluzioni tecnologiche, nuovi rischi	Nuova revisione PLN013

9. Risorse minime per la continuità

Ai fini del rispetto degli RTO/RPO definiti, sono garantite le seguenti risorse minime:

(a) Datacenter primario in colocation con SLA 99,9% e ridondanza alimentazione (UPS + generatore); (b) Backup off-site cifrato giornaliero su provider cloud diverso dal primario; (c) Connettività ridondata (almeno 2 carrier indipendenti); (d) Endpoint preconfigurati (10% in più rispetto al fabbisogno) per smart working d'emergenza; (e) Vendor di emergenza ICT pre-qualificati (intervento entro 4 ore); (f) Lista di laboratori partner per esami inviabili in caso di indisponibilità; (g) Reperibilità AD + IT Manager + RSGI in ogni momento.

10. KPI di continuità

KPI	Target	Frequenza misurazione
-----	--------	-----------------------

Rispetto RTO sui processi critici (in test e in incidente reale)	100%	Per evento + annuale
Rispetto RPO	100%	Per evento + annuale
% test annuali completati con successo	100%	Annuale
% personale CMT formato e disponibile	≥ 90%	Trimestrale
MTBF servizi critici (LIS, RIS, PACS)	≥ 720 ore (30 giorni)	Trimestrale
Tempo medio di recovery in incidenti reali	≤ RTO	Per evento

11. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	30/04/2026	Prima emissione del Business Continuity Plan in attuazione di ISO 22301 (framework metodologico) e in coerenza con ISO 27001 §A.5.29-A.5.30 e NIS2 area MTOM 3. Allineato al Piano MTOM PLN009 e completato dal DRP PLN014 (componente ICT). Test annuali tabletop integrati con tabletop NIS2 (MOD183). Chiude la NC Maggiore P1 #22 del RPT003.	IT Manager + RSGI + AD	AD